

source tools and common password lists to gain access to the system.

To take care of this, there should be regulations about having strong passwords, like imposing the use of alpha-numeric and symbolic characters. Go a step further and don't accept passwords with a first or last name of the user, etc.

We must also ensure that if we are storing login information in a session or cookies, it must be stored in an encrypted format.

Mobile app security testing

Given below are the commonly encountered threats that should be dealt with right from the onset.

Improper platform usage: This includes the exploitation of the phone's features or OS, by first asking for and getting app permissions to access contacts, gallery, etc, when there is really no need for such information to be shared.

Superfluous data storage: This is about storing unwanted data in the app.

Exposed authentication: This refers to cases of failing to identify the user or to maintain the user session.

Insecure communication: This is about failing to keep a correct SSL session.

Malicious third-party code: This refers to writing third-party code that is not needed or not removing unnecessary code.

Failure to apply server-side controls: The server should authorise what data needs to be shown in the app.

Client-side injection: This results in the injection of malicious code in the app.

Lack of data protection in transit: This refers to the failure to encrypt the data when sending or receiving it via a Web service.

Types of security testing

Vulnerability scanning: This is usually conducted via automated software — to scan a system against known vulnerability signatures.

Security scanning: This involves identifying network and system weaknesses, and can be performed both manually and in an automated manner.

Penetration testing: This simulates an attack from a malicious hacker. It involves testing a particular system to uncover potential vulnerabilities to hacking attempts.

Risk assessment: This testing involves an analysis of the security risks observed in the organisation. Risks are classified as either low, medium or high. This testing recommends controls and measures to reduce risks.

Security auditing: This is an internal inspection of applications and operating systems, in search of security flaws. An audit can also be done via line-by-line inspection of code.

Ethical hacking: This involves hacking an organisation's software systems to expose security flaws in the system.

Posture assessment: This combines security scanning, ethical hacking and risk assessments to show the overall security posture of an organisation.

Security testing tools

There are a number of security testing tools available on the market; some of the most popular ones are listed below.

1. **Burp** (community version): The Burp suite is a Java based Web penetration testing framework.
2. **Arachni:** This can be used to test for invalidated redirects, local and remote file inclusion, SQL injection, XSS injection, etc
3. **IronWasp:** This can uncover over 25 types of Web application vulnerabilities. Additionally, it can also detect false positives and false negatives. It helps identify broken authentication, cross-site scripting, CSRF, hidden parameters, privilege escalation, etc
4. **SonarQube:** In addition to exposing vulnerabilities, it is

used to measure the source code quality of a Web application. Despite being written in Java, SonarQube is able to carry out analysis of over 20 programming languages. It tackles cross-site scripting, Denial of Service (DoS) attacks, HTTP response splitting, memory corruption, SQL injection, detects tricky issues, DevOps integration, sets up the analysis of pull requests, supports quality tracking of both short-lived and long-lived code branches, visualises the history of a project, etc.

5. **Wfuzz:** This is popularly used for brute-forcing Web applications, as well as for LDAP injection, SQL injection, XSS injection, etc.
6. **Zed Attack Proxy (ZAP):** ZAP is used for finding a number of security vulnerabilities in a Web app during the development as well as testing phases. It tackles application error disclosure, missing anti-CSRF tokens and security headers, private IP disclosure, session IDs in URL rewrite, SQL injection and XSS injection.
7. **Wireshark:** This is an open source tool for profiling network traffic and analysing packets.
8. **Metasploit:** This provides useful information to those who perform penetration testing, IDS signature development and exploit research.
9. **Kali:** The Kali Linux penetration testing platform contains a vast array of tools and utilities, from information gathering to final reporting, that enable security and IT professionals to assess the security of their systems. **END** 🐧

By: Priyanka Shivkar

The author works as a senior UI developer. She is a bibliophile, a hardcore gamer and completely head over heels in love with the Angular framework.